

STRIDE Letter Card

Day 2 · Activity 1 handout. The six-letter threat taxonomy. Walk your feature's data flow and ask each question at every box (data at rest) and every arrow (data in motion).

Letter	Threat	Plain language	Ask at each step
S	Spoofing	Pretending to be someone you aren't	Can an attacker impersonate a user or a system here?
T	Tampering	Changing data without authorization	Can data be altered in transit or at rest?
R	Repudiation	Denying you did something you did	Can a user deny an action we can't prove?
I	Information disclosure	Exposing data to the wrong party	Can the wrong party read this data?
D	Denial of service	Blocking legitimate use	Can an attacker block legitimate use here?
E	Elevation of privilege	Doing more than your role allows	Can someone act beyond their role's scope?

The data-flow lens

A threat model is a walk along the **data flow** of your feature. Where does data come from, where does it move to, where does it stop, and who can read or change it at each step?

```
[User] →(auth)→ [Frontend] →(API)→ [Backend service]
      ↓
      [Datastore]
      ↓
      [Audit / events]
      ↓
      [Downstream consumer]
```

Threats live at the **arrows** (data in motion) and at the **boxes** (data at rest). Each STRIDE letter applies to one or more.

How to use the card

- Ask **all six** questions at **every** box and arrow. You will **not** find a threat for every letter at every step — that's expected. What matters is that the question was asked.
- **Repudiation is the least intuitive letter** — most people skip it. Force it: how do you prove a user did the thing they later deny?
- "Security" is not the same as "authentication." STRIDE forces the wider lens.